CRISC Exam - Domain 4: Technology & Security

Technology Risk Questions 106–145 with Explanations

Compiled from ISACA CRISC Review Manual 8th Edition

October 19, 2026

Outline

1. Cryptography & PKI
2. Security Awareness & Training
3. Data Privacy & Protection
4. Threat Landscape & Vulnerability Management

Q106: Digital Signature vs. Encryption

Question

A message that is signed but not encrypted provides:

- (A) Confidentiality but not integrity
- (B) Integrity and nonrepudiation but not confidentiality
- (C) Confidentiality, integrity, and nonrepudiation
- (D) None of the above

Q106: Explanation

Correct Answer: B

Digitally signing a message applies encryption only to the digest and does not make the message content confidential. A message may be encrypted and not signed (confidential but lacking integrity or nonrepudiation), signed and not encrypted (not confidential but with integrity and nonrepudiation), or signed and encrypted (confidential with integrity and nonrepudiation).

Option Analysis

- **A - Incorrect:** Signed-only messages are not confidential
- **B - Correct:** Signed-only provides integrity and nonrepudiation
- **C - Incorrect:** Confidentiality requires encryption of the message
- **D - Incorrect:** Signed-only does provide two protections

Q107: Certificate Authority Purpose

Question

What is the purpose of a certificate authority (CA)?

A. To encrypt all network traffic

B. To link public keys with specific owners by verifying identity and generating certificates on behalf of the public key owner

C. To store all organizational data

D. To replace firewalls

Q107: Explanation

Correct Answer: B

Public key encryption does not prove that the person who owns the public key being distributed is who he or she claims to be. Certificates link public keys with specific owners by relying on the endorsement of a trusted third party known as a certificate authority (CA). The CA verifies identity by other means and generates the certificate on behalf of the owner of a public key.

Option Analysis

- **A - Incorrect:** CAs do not encrypt traffic
- **B - Correct:** CAs verify identity and issue certificates
- **C - Incorrect:** CAs do not store organizational data
- **D - Incorrect:** CAs do not replace firewalls

Q108: Certificate Revocation List

Question

What happens when a certificate is placed on a certificate revocation list (CRL)?

A. The certificate is automatically renewed

B. Requests to validate the certificate result in a notification that the certificate has been revoked, warning that it should not be trusted

C. The certificate becomes more trusted

D. The certificate owner is notified to change their password

Q108: Explanation

Correct Answer: B

The owner of a certificate may cancel it at any time during its validity period by notifying the CA, which will put the certificate on a certificate revocation list (CRL). Requests to validate a certificate that is on a CRL result in a notification that the certificate has been revoked, warning that the certificate should not be trusted as a means of verifying identity.

Option Analysis

- **A - Incorrect:** Revocation is not renewal
- **B - Correct:** Revoked certificates are not trusted
- **C - Incorrect:** Revocation reduces trust
- **D - Incorrect:** CRLs are about certificates, not passwords

Q109: PKI Cross-Certification

Question

What is required when members of different PKI implementations are linked by relationships established between their respective CAs?

A. Nothing; links happen automatically

B. A cross-certification agreement to provide a policy basis for the inter-connectivity

C. All certificates must be revoked

D. A new root CA must be created

Q109: Explanation

Correct Answer: B

PKI implementations may be connected to one another and allow certificate verification using an external CA. When members of different PKI implementations are linked by relationships established between their respective CAs, a cross-certification agreement should be in place to provide a policy basis for this inter-connectivity.

Option Analysis

- **A - Incorrect:** Links require explicit agreements
- **B - Correct:** Cross-certification provides the policy basis
- **C - Incorrect:** Revocation is not required for linking
- **D - Incorrect:** A new root CA is not required

Q110: Certificate Expiration Risk

Question

What happens if certificates are not renewed prior to expiration?

A. Nothing changes

B. Results may include loss of access to encrypted messages and communications channels that depend on PKI-authenticated access

C. Certificates become more trusted

D. The CA is automatically notified

Q110: Explanation

Correct Answer: B

The risk practitioner should ensure that mechanisms for certificate management are in place so certificates can be renewed prior to expiration. Once a certificate expires, results may include loss of access to encrypted messages and communications channels that depend on PKI-authenticated access.

Option Analysis

- **A - Incorrect:** Expiration causes access loss
- **B - Correct:** Expiration causes loss of access
- **C - Incorrect:** Expiration reduces trust
- **D - Incorrect:** Renewal requires proactive action

Q111: Encryption Disadvantage

Question

Which of the following is a disadvantage of encryption?

A. It improves system performance

B. It requires processing and its demands increase with the length of the key and strength of the algorithm

C. It reduces network traffic

D. It eliminates the need for key management

Q111: Explanation

Correct Answer: B

One disadvantage of encryption is that it requires processing and its demands increase with the length of the key and strength of the algorithm. Encryption also increases network traffic based on the need to verify certificates, particularly in cases with large numbers of small messages. The increased processing and transmission demands mean encryption should be used only when necessary.

Option Analysis

- **A - Incorrect:** Encryption adds processing overhead
- **B - Correct:** Processing demands increase with key length
- **C - Incorrect:** Encryption can increase network traffic
- **D - Incorrect:** Encryption requires key management

Q112: Encryption Fail-Secure

Question

Why is encryption not a fail-secure control?

A. Because it always fails

B. Because if keys are corrupted or lost, encrypted data will not be immediately recoverable and, in some cases, may not be recoverable at all

C. Because it has no security value

D. Because keys are never needed

Q112: Explanation

Correct Answer: B

The risk practitioner should understand that encryption is not a fail-secure control: if keys are corrupted or lost, encrypted data will not be immediately recoverable and, in some cases, may not be recoverable at all. This presents a challenge to data availability.

Option Analysis

- **A - Incorrect:** Encryption does not always fail
- **B - Correct:** Lost keys make data unrecoverable
- **C - Incorrect:** Encryption is vital to security
- **D - Incorrect:** Keys are essential for decryption

Q113: Symmetric vs. Asymmetric Strengths

Question

Which statement correctly describes the respective strengths of symmetric and asymmetric encryption?

A. Symmetric is slow; asymmetric is fast

B. Symmetric is excellent for confidentiality of large messages; asymmetric is used to securely exchange symmetric keys

C. Both are equally fast

D. Neither provides confidentiality

Q113: Explanation

Correct Answer: B

Symmetric encryption algorithms are excellent at providing confidentiality to large messages, but managing shared secret keys is difficult. Asymmetric algorithms are much slower, but keys can be securely exchanged between users. Because of these respective strengths, asymmetric algorithms are used to send symmetric keys, which are then used to encrypt messages.

Option Analysis

- **A - Incorrect:** Symmetric is fast; asymmetric is slow
- **B - Correct:** Symmetric for bulk; asymmetric for key exchange
- **C - Incorrect:** They differ significantly in speed
- **D - Incorrect:** Both provide confidentiality

Q114: Social Engineering - Weakest Link

Question

Why are human users considered the weakest link in information security?

A. Because they are not needed

B. Because security technology has improved dramatically, but human users are more vulnerable than ever and accustomed to freely sharing information

C. Because they always follow procedures

D. Because they have no access to systems

Q114: Explanation

Correct Answer: B

Current threat actors have correctly identified human users as the weakest link in the information security foundation of modern enterprises. Security technology has improved dramatically; in contrast, human users are more vulnerable than ever. Employees accustomed to freely sharing information on social media may make information more widely available than authorized by organizational policy.

Option Analysis

- **A - Incorrect:** Humans are essential to operations
- **B - Correct:** Human vulnerability has increased
- **C - Incorrect:** Users often work around procedures
- **D - Incorrect:** Users have significant system access

Q115: Primary Purpose of Security Training

Question

What is the primary concern that should be given to teaching people in a security awareness program?

A. Teaching them to write code

B. Teaching them to recognize social engineering techniques intended to get them to carry out tasks that benefit malicious agendas

C. Teaching them to configure firewalls

D. Teaching them to manage databases

Q115: Explanation

Correct Answer: B

The foremost concern should be given to teaching people to recognize social engineering techniques intended to get them to carry out tasks that benefit malicious agendas. The actual tasks tend to be simple, such as clicking a link, providing a phone number, or opening an attachment, but these tasks fit into larger plans to deploy malware, take over accounts, or provide leverage to reach further into an enterprise.

Option Analysis

- **A - Incorrect:** Coding is not the focus of awareness training
- **B - Correct:** Recognize social engineering techniques
- **C - Incorrect:** Firewall configuration is technical training
- **D - Incorrect:** Database management is technical training

Q116: Awareness Training Minimum Scope

Question

At a minimum, an information security training and awareness program should address which three things?

A. Coding, testing, and deployment

B. Threats from social engineering, methods of alerting internal security capabilities, and policies and regulatory requirements specific to the enterprise

C. Budgeting, staffing, and scheduling

D. Hardware, software, and networks

Q116: Explanation

Correct Answer: B

At a minimum, the program should address: threats from social engineering including phishing and vishing; methods of alerting internal security capabilities such as an IT service desk or incident response team; and policies and regulatory requirements specific to the enterprise or its business sector.

Option Analysis

- **A** - **Incorrect:** These are technical SDLC activities
- **B** - **Correct:** Social engineering, alerting, policies
- **C** - **Incorrect:** These are management activities
- **D** - **Incorrect:** These are technology domains

Q117: Ethical Phishing Exercises

Question

Why do organizations implement ethical phishing email exercises?

A. To punish employees who fail

B. To assess how easy it is for employees to fall victim to a phishing scam and measure the level of exposed risk

C. To increase employee productivity

D. To replace all other security controls

Q117: Explanation

Correct Answer: B

It is common to implement ethical phishing email exercises to assess how easy it is for employees to fall victim to a phishing scam. As a result, the enterprise can measure the level of exposed risk and the necessity of improving the awareness programs in place.

Option Analysis

- **A - Incorrect:** Exercises are for learning, not punishment
- **B - Correct:** Measure exposure and program necessity
- **C - Incorrect:** Exercises are not for productivity
- **D - Incorrect:** They complement, not replace, controls

Q118: Role-Based Training

Question

Why do leading enterprises incorporate role-based training for administrators and others handling sensitive tasks?

A. To reduce training costs
B. As a way of mitigating role-specific risk
C. To comply with all regulations
D. To replace general awareness training

Q118: Explanation

Correct Answer: B

Leading enterprises also incorporate role-based training for administrators and others in roles that handle sensitive tasks or data as a way of mitigating role-specific risk. This training goes beyond general awareness to address the specific threats and responsibilities of particular roles.

Option Analysis

- **A** - **Incorrect:** Role-based training may increase costs
- **B** - **Correct:** Mitigates role-specific risk
- **C** - **Incorrect:** Compliance is secondary to risk mitigation
- **D** - **Incorrect:** It complements general awareness

Q119: Human Firewall Concept

Question

How can properly trained human judgment serve as a first line of defense?

- (A) By replacing all technical controls
- (B) By helping identify attacks in progress even when directed elsewhere and alerting response capabilities within the organization
- (C) By eliminating all risk
- (D) By automating all security processes

Q119: Explanation

Correct Answer: B

Human users are also the first line of defense. Properly trained, human judgment can help identify attacks in progress even when directed elsewhere. By alerting response capabilities within the organization, resilient people help create a resilient workforce, which in turn improves organizational information and cybersecurity.

Option Analysis

- **A - Incorrect:** Technical controls are still essential
- **B - Correct:** Trained humans identify and alert
- **C - Incorrect:** No control eliminates all risk
- **D - Incorrect:** Humans complement automation

Q120: GDPR Seven Principles

Question

Which of the following correctly lists key GDPR principles?

- A Profitability, efficiency, secrecy
- B Lawfulness/fairness/transparency, purpose limitation, data minimization, accuracy, storage limitation, integrity/confidentiality, accountability
- C Availability, integrity, confidentiality
- D Identify, assess, respond, monitor

Q120: Explanation

Correct Answer: B

The GDPR establishes seven key principles: lawfulness/fairness/transparency, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, and accountability. The GDPR applies to data stored anywhere in the European Union and sets limits on the transfer to other jurisdictions of covered data associated with EU citizens.

Option Analysis

- **A - Incorrect:** Not GDPR principles
- **B - Correct:** The seven GDPR principles
- **C - Incorrect:** These are the CIA triad
- **D - Incorrect:** These are risk management phases

Q121: GDPR Penalties

Question

What is the maximum potential penalty for violations of GDPR?

- A 1,000 Euros
- B Up to 20 million Euros or 4% of an enterprise's prior-year income
- C 100,000 Euros
- D There are no penalties

Q121: Explanation

Correct Answer: B

As penalties associated with noncompliance increase—for instance, violations of GDPR can extend as high as 20 million Euros or 4% of an enterprise's prior-year income—enterprises are finding it increasingly important to manage these areas of risk.

Option Analysis

- **A - Incorrect:** Far too low
- **B - Correct:** Up to 20M Euros or 4% of income
- **C - Incorrect:** Far too low
- **D - Incorrect:** Significant penalties exist

Q122: Privacy vs. Confidentiality

Question

What distinguishes privacy from confidentiality?

- A They are identical concepts
- B An individual identified by information subject to privacy controls has rights regarding the handling and retention of that data, even if that person is not the data owner
- C Confidentiality only applies to paper records
- D Privacy only applies to digital data

Q122: Explanation

Correct Answer: B

At its essence, privacy is very similar to confidentiality: the goal is to ensure no one gets access to information who should not have it. What distinguishes privacy is that an individual identified by information subject to privacy controls—the subject—has rights regarding the handling and retention of that data, even if that person is not the data owner. Privacy breaches may also arise from data unintentionally revealed by other data through implication or association.

Option Analysis

- **A - Incorrect:** They are related but distinct
- **B - Correct:** Data subject rights distinguish privacy
- **C - Incorrect:** Confidentiality applies to all formats
- **D - Incorrect:** Privacy applies beyond digital data

Q123: Informed Consent Revocation

Question

What must a privacy program provide regarding informed consent?

- A Only a signed consent form
- B A process for revocation of consent in addition to obtaining consent
- C A one-time consent that cannot be changed
- D No consent at all

Q123: Explanation

Correct Answer: B

Data subject to privacy regulations should be collected, used, and retained with the informed consent of the subject. A signed consent form is typically part of the process but may not be enough to establish informed consent. In addition, there may need to be a process for revocation of consent.

Option Analysis

- **A** - **Incorrect:** A form alone may not establish informed consent
- **B** - **Correct:** Revocation process is required
- **C** - **Incorrect:** Consent must be revocable
- **D** - **Incorrect:** Consent is required for data collection

Q124: Privacy Impact Assessment Focus

Question

How does a privacy impact assessment (PIA) differ from a risk assessment?

- A PIA accounts for the effects of a compromise on the subject rather than impact to the enterprise
- A PIA only assesses financial risk
- A PIA replaces the need for risk assessment
- A PIA focuses only on technical controls

Q124: Explanation

Correct Answer: A

Organizations conduct PIAs to identify and manage risk related to privacy whenever personal information is collected. The PIA typically covers how information is used, shared, and maintained. Similar to a risk assessment, a PIA accounts for the effects of a compromise on the subject rather than impact to the enterprise.

Option Analysis

- **A - Correct:** PIA focuses on harm to the subject
- **B - Incorrect:** PIA covers more than financial risk
- **C - Incorrect:** PIA complements risk assessment
- **D - Incorrect:** PIA includes nontechnical considerations

Q125: Data Minimization Rationale

Question

Why is data minimization a key privacy principle?

- A To reduce storage costs
- B Because data accumulated without limit is a potential disaster for enterprises subject to strong privacy regulations should a data breach occur
- C To improve system performance
- D To simplify backups

Q125: Explanation

Correct Answer: B

Many enterprises accumulate considerable data and retain it without limit. Risk practitioners should understand that this data, which may be viewed as an asset, is also a potential disaster for enterprises subject to strong privacy regulations should a data breach occur. Privacy is best assured when only data that is expressly needed and relevant for a particular purpose is collected.

Option Analysis

- **A - Incorrect:** Cost is a secondary benefit
- **B - Correct:** Less data reduces breach impact
- **C - Incorrect:** Performance is a secondary benefit
- **D - Incorrect:** Backups are secondary

Q126: Data Destruction and Legal Retention

Question

What should be done when data must be retained for specific periods according to law or regulation, even though it is no longer needed for its original purpose?

A. Destroy it immediately regardless of law
B. Implement access restrictions to the data
C. Share it publicly
D. Ignore the data

Q126: Explanation

Correct Answer: B

Just as data should be collected only when necessary, it should generally be destroyed once its purpose is concluded. Destruction can be complicated, because there are some types of data that must be retained for specific periods according to law or regulation, and contractual obligations may also impose specific parameters for destruction. In this case, it is important to implement access restrictions to the data.

Option Analysis

- **A** - **Incorrect:** Legal requirements must be followed
- **B** - **Correct:** Access restrictions protect retained data
- **C** - **Incorrect:** Sharing publicly violates privacy
- **D** - **Incorrect:** Ignoring data increases risk

Q127: Privacy Context - Least Privilege

Question

How does the principle of least privilege apply in a privacy context?

- A. All employees should have access to all private data
- B. Access to information subject to privacy considerations should be limited to individuals with a valid business need and limited according to least privilege
- C. Only the IT department should have access
- D. Privacy data should be freely shared

Q127: Explanation

Correct Answer: B

Access to information subject to privacy considerations should be limited to individuals with a valid business need, and the extent of that access should be limited according to the principle of least privilege. Many enterprises segregate duties for release of private data to serve as checks against accidental release.

Option Analysis

- **A - Incorrect:** Broad access violates privacy
- **B - Correct:** Need-to-know and least privilege
- **C - Incorrect:** IT does not need all data access
- **D - Incorrect:** Privacy data requires protection

Q128: Privacy Expert Consultation

Question

What is perhaps the most important function an IT risk practitioner has in controlling privacy risk?

A. Making all privacy decisions independently

B. Recognizing that there may be considerations beyond his or her knowledge and consulting with organizational privacy officers or experts

C. Ignoring privacy concerns

D. Delegating all privacy matters to IT

Q128: Explanation

Correct Answer: B

Perhaps the most important function that an IT risk practitioner has in controlling privacy risk is recognizing that there may be considerations and factors beyond his or her knowledge and ability to predict. Data privacy is a comprehensive field involving multiple principles, frameworks, and standards in addition to legal and regulatory requirements that vary widely. Risk practitioners should consult with organizational privacy officers or privacy experts.

Option Analysis

- **A - Incorrect:** Privacy requires expert input
- **B - Correct:** Recognize limitations and consult experts
- **C - Incorrect:** Ignoring privacy increases risk
- **D - Incorrect:** Privacy is an enterprise concern

Q129: Privacy Regulation Conflict

Question

What should a risk practitioner be aware of regarding privacy regulations across jurisdictions?

A. All jurisdictions have identical privacy laws

B. Rules applicable to certain contexts may conflict with those that apply to other contexts, including geography and types of data

C. Privacy laws never change

D. Only one country has privacy laws

Q129: Explanation

Correct Answer: B

Practitioners should be aware that privacy is a dynamic field subject to regular changes and that rules applicable to certain contexts may conflict with those that apply to other contexts, including geography and types of data. Even in a cloud environment, physical storage of data may impose obligations, and international agreements are not always reliable over the long term.

Option Analysis

- **A - Incorrect:** Privacy laws vary widely
- **B - Correct:** Rules may conflict across contexts
- **C - Incorrect:** Privacy laws change regularly
- **D - Incorrect:** Many countries have privacy laws

Q130: Safe Harbor Invalidation

Question

What happened to the US-EU Safe Harbor program established to facilitate compliance with GDPR?

A. It remains fully valid

B. It was declared insufficient by a European court in 2020

C. It was expanded to include more countries

D. It was never created

Q130: Explanation

Correct Answer: B

The US-EU "Safe Harbor" program established to facilitate compliance with GDPR was declared insufficient by a European court in 2020. This illustrates that international agreements are not always reliable over the long term, and each set of laws and regulations specific to a given context should be given appropriate study.

Option Analysis

- **A - Incorrect:** It was invalidated
- **B - Correct:** Declared insufficient in 2020
- **C - Incorrect:** It was not expanded
- **D - Incorrect:** It existed and was invalidated

Q131: Internal Threat - Disgruntled Employee

Question

What is the typical profile of a malicious insider?

- A. An external hacker with no organizational access
- B. A current or former employee, contractor, or business partner who has or had authorized access and intentionally intercepts, interrupts, modifies, or fabricates data
- C. A random person on the internet
- D. An automated bot

Q131: Explanation

Correct Answer: B

The typical malicious insider is a current or former employee, contractor, or other business partner who has or had authorized access to an organization's network, system, or data and has intentionally intercepted, interrupted, modified, or fabricated data in the organization's information systems. During times of strike, layoffs, mergers, relocation, and reorganization, an employee is more likely to be a threat.

Option Analysis

- **A** - **Incorrect:** Insiders have authorized access
- **B** - **Correct:** Current/former employee with access
- **C** - **Incorrect:** Random persons lack access
- **D** - **Incorrect:** Bots are not insiders

Q132: Personnel Threat Mitigation First Step

Question

What is the first step in addressing personnel threats?

- A Implementing monitoring tools
- B Starting with the hiring process and reviewing qualifications and attitude of prospective employees
- C Installing antivirus software
- D Conducting penetration testing

Q132: Explanation

Correct Answer: B

The first step in addressing personnel threats is to start with the hiring process and review the qualifications and attitude of prospective employees. At the time of hiring, the employee should be required to sign a nondisclosure agreement (NDA) and be advised of the ethics and policies of the enterprise. Checking references and performing background checks may be worthwhile where permitted by law.

Option Analysis

- **A** - **Incorrect:** Monitoring comes later
- **B** - **Correct:** Hiring process is the first step
- **C** - **Incorrect:** Antivirus is a technical control
- **D** - **Incorrect:** Penetration testing is external

Q133: Employee Departure Controls

Question

What should happen to system access when an employee departs the organization?

A. Access should remain active indefinitely

B. Access should be revoked immediately prior to the employee's departure, and all organizational assets should be returned

C. Access should be revoked after 30 days

D. No action is needed

Q133: Explanation

Correct Answer: B

At the end of employment, an employee should return all organizational assets, including identification badges, equipment, and uniforms so they cannot use those to gain unauthorized access in the future. Systems, network, and facility access should be revoked immediately prior to the employee's departure to minimize the potential for crimes of opportunity or retaliation.

Option Analysis

- **A - Incorrect:** Access must be revoked
- **B - Correct:** Revoke access and return assets
- **C - Incorrect:** Immediate revocation is required
- **D - Incorrect:** Action is essential

Q134: Third-Party Internal Threat

Question

Why do third parties with internal access pose an internal threat?

- A Because they are always malicious
- B Because they usually have internal access points and higher knowledge and capabilities to potentially initiate a threat from within an enterprise
- C Because they have no access
- D Because they cannot cause harm

Q134: Explanation

Correct Answer: B

Internal threats can also originate from third parties who have access to internal systems or process data on behalf of the organization. Risk practitioners should also consider vendor staff, business process outsourcing staff, and any other external individuals that have been granted access. Although they can be considered external threats, they usually have some internal access points and higher knowledge and capabilities to potentially initiate a threat from within an enterprise.

Option Analysis

- **A - Incorrect:** Not all third parties are malicious
- **B - Correct:** Internal access and knowledge create risk
- **C - Incorrect:** They do have access
- **D - Incorrect:** They can cause harm

Q135: External Threat - Most Breaches

Question

According to Verizon's Data Breach Investigations Report, most breaches are the result of:

A. Highly sophisticated nation-state attacks
B. Targets of opportunity rather than determined attacks
C. Insider threats
D. Physical theft

Q135: Explanation

Correct Answer: B

Most breaches are the result of targets of opportunity, not determined attacks. As seen in the annual reports from Verizon, ways-in analysis witnessed substantial growth of attacks involving the exploitation of vulnerabilities as the critical path to initiate a breach when compared to previous years.

Option Analysis

- **A - Incorrect:** Nation-state attacks are less common
- **B - Correct:** Targets of opportunity
- **C - Incorrect:** Insider threats are a subset
- **D - Incorrect:** Physical theft is less common

Q136: APT Characteristics

Question

What characterizes an advanced persistent threat (APT)?

A. Low skill and undetermined effort

B. Advanced skills, determination (persistence), and significant resources, often sponsored by governments, organized crime, or competitors

C. Random and opportunistic attacks

D. Limited to physical attacks

Q136: Explanation

Correct Answer: B

The term APT refers to advanced, highly skilled attackers that are determined (persistent) in their attempts to exploit systems and networks. Their increased skills and the effectiveness of the tools they possess make the risk of compromise significant. APTs may be sponsored by governments, organized crime, or competitors.

Option Analysis

- **A - Incorrect:** APTs are highly skilled
- **B - Correct:** Advanced, persistent, well-resourced
- **C - Incorrect:** APTs are targeted, not random
- **D - Incorrect:** APTs use multiple vectors

Q137: Emerging Threat Indicators

Question

Which of the following may indicate an emerging threat?

- A Normal system performance
- B Unusual activity on a system, repeated alarms, degraded performance, or new or excessive activity in logs
- C Regular scheduled maintenance
- D Routine user logins

Q137: Explanation

Correct Answer: B

Indications of emerging threats may include unusual activity on a system, repeated alarms, degraded system or network performance, or new or excessive activity in logs. In many cases, compromised organizations have evidence of emergent threats in their logs well in advance of the actual compromise, but the evidence is either not acted on or not noticed.

Option Analysis

- **A - Incorrect:** Normal performance is not an indicator
- **B - Correct:** Unusual activity indicates emerging threat
- **C - Incorrect:** Maintenance is routine
- **D - Incorrect:** Routine logins are normal

Q138: Threat Information Sources

Question

Which of the following is a valuable source of threat information for the risk practitioner?

A. Only internal audit reports
B. CERT advisories, security company reports, media reports, and peer organizations
C. Only social media
D. Only vendor marketing materials

Q138: Explanation

Correct Answer: B

Annual reports from antivirus, security, and telecommunications companies provide a summary review of risk and exposure factors observed in the field and may assist in developing and presenting risk management solutions to management. Information on incidents and risk may also come from computer or cybersecurity monitoring and reporting services by government and nonprofit organizations.

Option Analysis

- **A - Incorrect:** Internal audit is only one source
- **B - Correct:** Multiple external sources are valuable
- **C - Incorrect:** Social media alone is insufficient
- **D - Incorrect:** Marketing materials are biased

Q139: Threat Modeling Methods - STRIDE

Question

What does the STRIDE threat modeling method evaluate?

- A Financial risk only
- B Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, and Elevation of privilege
- C Only network vulnerabilities
- D Only physical security

Q139: Explanation

Correct Answer: B

STRIDE evaluates the system detail design and models the in-place system. By building dataflow diagrams (DFDs), STRIDE is used to identify system entities, events, and the boundaries of the system. It helps identify relevant mitigating techniques and is the most mature threat-modeling method.

Option Analysis

- **A - Incorrect:** STRIDE is not financial
- **B - Correct:** The six STRIDE categories
- **C - Incorrect:** STRIDE covers more than network
- **D - Incorrect:** STRIDE is design-focused

Q140: PASTA Threat Modeling

Question

What is the primary focus of the PASTA threat modeling method?

- A Privacy concerns only
- B A risk-centric framework that aims to bring business objectives and technical requirements together
- C Automated code review
- D Network scanning

Q140: Explanation

Correct Answer: B

PASTA (Process for Attack Simulation and Threat Analysis) is a risk-centric threat-modeling framework. It aims to bring business objectives and technical requirements together, contains built-in prioritization of threat mitigation, and encourages collaboration among stakeholders. It is laborious but has rich documentation.

Option Analysis

- **A** - **Incorrect:** LINDDUN focuses on privacy
- **B** - **Correct:** PASTA is risk-centric
- **C** - **Incorrect:** Automated code review is separate
- **D** - **Incorrect:** Network scanning is separate

Q141: Vulnerability Assessment Purpose

Question

What is the purpose of vulnerability identification?

A. To find problems before an adversary does and exploits them
B. To eliminate all vulnerabilities
C. To replace risk assessment
D. To punish system owners

Q141: Explanation

Correct Answer: A

The purpose of vulnerability identification is to find the problems before they are found by an adversary and exploited. This is why an enterprise should conduct regular vulnerability assessments and penetration tests to identify, validate, and classify its vulnerabilities.

Option Analysis

- **A - Correct:** Find problems before adversaries
- **B - Incorrect:** Not all vulnerabilities can be eliminated
- **C - Incorrect:** Vulnerability assessment complements risk assessment
- **D - Incorrect:** Assessment is not punitive

Q142: Common Vulnerability Scoring System

Question

Which Common Vulnerability Scoring System (CVSS) metric group defines inherent characteristics of a vulnerability that remain constant across environments?

A. Base metrics
B. Temporal metrics
C. Environmental metrics
D. Foundational metrics

Q142: Explanation

Correct Answer: A

Base metrics define the inherent characteristics of a vulnerability that remain constant across environments. Temporal metrics reflect the current state of exploitability and remediation, which may change over time. Environmental metrics customize the score based on the vulnerability's impact within a specific organizational context.

Option Analysis

- **A - Correct:** Base metrics are constant
- **B - Incorrect:** Temporal metrics change over time
- **C - Incorrect:** Environmental metrics are org-specific
- **D - Incorrect:** Foundational is not a CVSS metric group

Q143: False Positives and Zero-Day Exploits

Question

What does it mean when a vulnerability assessment identifies no vulnerabilities in a system?

A. The system is completely invulnerable

B. It means only that the types of vulnerabilities the assessment was intended to detect were not detected—the system may remain vulnerable to unknown vulnerabilities

C. The system is not connected to the network

D. The assessment was successful

Q143: Explanation

Correct Answer: B

A vulnerability assessment that identifies no vulnerabilities is not equal to the system being invulnerable in the absolute sense. It means only that the types of vulnerabilities the assessment was intended to detect were not detected. Even if no known vulnerabilities exist within the system, the system may remain vulnerable to unknown vulnerabilities, some of which are stored or sold for future use as zero-day exploits.

Option Analysis

- **A - Incorrect:** No system is invulnerable
- **B - Correct:** Absence of detection is not absence of risk
- **C - Incorrect:** Network connection is unrelated
- **D - Incorrect:** The assessment may have limitations

Q144: Threat Matrix Purpose

Question

Why might a risk practitioner develop a threat actor profile or threat matrix?

- A To eliminate all threat actors
- B To reasonably account for certain elements associated with motivation and capabilities that could be brought to bear against the enterprise
- C To replace risk assessment
- D To publish publicly

Q144: Explanation

Correct Answer: B

By developing a threat actor profile, the risk practitioner can reasonably account for certain elements associated with motivation and capabilities that could be brought to bear against the enterprise. The threat matrix helps categorize the threat that a group of threat actors may pose to an enterprise's environment.

Option Analysis

- **A - Incorrect:** Threat actors cannot be eliminated
- **B - Correct:** Account for motivation and capabilities
- **C - Incorrect:** Threat profiling complements risk assessment
- **D - Incorrect:** Threat profiles are typically confidential

Q145: Root Cause Analysis

Question

What is the purpose of root cause analysis in risk management?

A. To punish individuals responsible for incidents

B. To establish the origins of events so that lessons can be learned and the problem can be prevented from recurring

C. To calculate annual loss expectancy

D. To replace risk assessment

Q145: Explanation

Correct Answer: B

Root cause analysis is a process of diagnosis to establish the origins of events so that lessons can be learned from consequences. A prudent risk practitioner examines the root cause of an incident to discover the conditions and factors that led to the event, rather than reacting to the symptoms of the problem.

Option Analysis

- **A - Incorrect:** RCA is for learning, not punishment
- **B - Correct:** Establish origins to prevent recurrence
- **C - Incorrect:** ALE is quantitative analysis
- **D - Incorrect:** RCA complements risk assessment

Domain 4 Key Takeaways

Essential Concepts

- Signed-only messages provide integrity/nonrepudiation, not confidentiality
- CAs verify identity and issue certificates; CRLs revoke them
- Encryption adds processing overhead and is not fail-secure
- Symmetric is fast for bulk data; asymmetric is slow but solves key distribution
- Humans are the weakest link; awareness training is essential
- GDPR: lawfulness, purpose limitation, minimization, accuracy, storage, integrity, accountability
- Privacy differs from confidentiality because data subjects have rights
- PIAs focus on harm to the individual; minimization reduces breach impact
- Insiders and third parties with access are significant threats
- APTs are advanced, persistent, and well-resourced

Final Advice

Exam Preparation

Remember:

- Understand the *why* behind each technology risk concept
- Know the difference between similar terms
- Understand how emerging technologies introduce new risk
- Practice scenario-based questions
- Use the ISACA mindset

Good Luck on Your CRISC Exam!